

Vulnerability Management Policy and Standard

NOVAtech Inc. | Simulated for demonstration

Document	Vulnerability Management Policy and Standard
Version	1.0
Owner	Head of Security
Approved by	Chief Technology Officer
Effective date	2026-08-03
Next review	Annually or on significant change
Framework alignment	ISO/IEC 27001:2022 A.8.8 (Management of technical vulnerabilities); CIS Controls v8 Control 7; SOC 2 CC7.1

1. PURPOSE

This policy establishes NOVAtech's approach to identifying, evaluating, and remediating technical vulnerabilities across systems and services within the ISMS scope. The purpose is to reduce the likelihood and impact of vulnerability exploitation, ensure timely remediation commensurate with risk, and provide auditable evidence of program operation.

2. SCOPE

This policy applies to all production, corporate, and cloud infrastructure identified as in-scope in the NOVAtech Asset Inventory (Project 4A), all software developed or operated by NOVAtech, and all third-party components deployed within scope. It applies to Security Operations, Engineering, IT, and asset owners across all business functions in scope.

Explicitly out of scope: the marketing website (asset A-23, hosted separately with no personal or customer data), penetration testing findings (governed under a separate testing policy), and code-quality issues not classified as security vulnerabilities.

3. ROLES AND RESPONSIBILITIES

Role	Responsibility
Chief Technology Officer	Approves the policy; adjudicates exceptions exceeding 90 days; accountable for enterprise vulnerability posture
Head of Security	Owns the policy; publishes metrics monthly; approves exceptions up to 90 days
Security Operations	Operates scanning; triages results; enriches with threat context; tracks remediation to closure
System / Asset Owners	Remediate vulnerabilities within SLA; request exceptions when remediation is not feasible; implement compensating controls
GRC	Maintains the exception register; reports SLA compliance to management review; flags trends

4. POLICY STATEMENTS

4.1 Vulnerability identification

- Authenticated vulnerability scans SHALL be performed on all in-scope infrastructure. Frequency: internet-facing systems weekly; internal and cloud infrastructure monthly; on-demand scans triggered by significant change (new production deployments, architecture changes).
- Software supply chain vulnerabilities SHALL be identified through dependency scanning integrated into the CI/CD pipeline for every build.
- Publicly disclosed vulnerabilities affecting deployed software or infrastructure SHALL be evaluated within 5 business days of disclosure, with priority based on CISA KEV listing, EPSS score, and asset criticality.

4.2 Prioritization

1. Vulnerability severity SHALL be determined using a combination of CVSS base score, exploitability signals (CISA KEV listing, EPSS score), and asset criticality from the Asset Inventory. CVSS alone SHALL NOT be the sole determinant of remediation priority.
2. Any vulnerability appearing on the CISA Known Exploited Vulnerabilities (KEV) catalog SHALL be treated as Critical severity regardless of CVSS score.
3. Vulnerabilities on Critical-classified assets (per Asset Inventory) SHALL receive one severity tier of elevated priority (e.g., a Medium vulnerability on a Critical asset is treated as High).

4.3 Remediation SLAs

Time-to-remediate is measured from vulnerability identification (scan completion or disclosure receipt) to verified closure.

Severity	Internet-facing	Internal	Notes
Critical (or on CISA KEV)	7 days	14 days	KEV-listed vulnerabilities inherit Critical SLA regardless of CVSS score
High	30 days	30 days	EPSS >0.5 accelerates to 14 days on internet-facing systems
Medium	90 days	90 days	
Low	180 days	180 days	Batched into quarterly patch cycles where operationally reasonable
Actively exploited (any severity)	72 hours	7 days	Confirmed in-the-wild exploitation overrides standard SLA

1. SLA is met when the vulnerability is remediated OR an approved exception is on file OR a documented false-positive determination is recorded.
2. Verification of closure SHALL be by rescan or equivalent evidence, not by remediation ticket status alone.

4.4 Exception process

1. Where remediation within SLA is not feasible, the asset owner SHALL submit a Risk Acceptance form to the Head of Security. The form MUST include: affected system, vulnerability details, business justification, compensating controls, residual risk assessment, and requested duration.
2. Exception duration MAY NOT exceed 90 days on initial approval. One renewal of up to 90 days is permitted with CTO approval. No exception SHALL be open-ended.
3. Approved exceptions SHALL be recorded in the Exception Register with unique identifier, expiry date, and owner. All exceptions SHALL be reviewed monthly by GRC.
4. On exception expiry, the underlying vulnerability MUST be remediated or a new exception approved. Silent expiry constitutes an SLA breach.

4.5 Verification and evidence

1. All scan results, remediation actions, and exceptions SHALL be preserved for a minimum of 24 months to support audit and regulatory inquiries.
2. The Exception Register and monthly metrics SHALL be reviewed at the quarterly management review (ISO 27001 Clause 9.3).

5. METRICS AND REPORTING

The following metrics SHALL be reported monthly to security leadership and quarterly to management review:

Metric	Target	Purpose
SLA compliance % (Critical)	≥ 95%	Primary program health indicator; reported monthly
SLA compliance % (High)	≥ 90%	Secondary indicator; trends inform capacity planning
Mean time to remediate (Critical)	< 5 days	Efficiency measure; complements SLA %
Open vulnerabilities aged >90 days	Trending down	Backlog health; count and aging distribution

Active exceptions	Trending flat or down	Growth signals systemic remediation issues
Coverage: assets scanned / total in scope	≥ 98%	Scanning is only as good as its coverage

6. ENFORCEMENT

Violations of this policy, including undocumented SLA breaches, unapproved exceptions, or systematic failure to remediate, SHALL be reported as nonconformities to the ISMS and addressed through corrective action per Clause 10.1. Persistent violations by asset owners may result in escalation to executive leadership.

7. RELATED DOCUMENTS

- Information Security Policy (Project 8)
- Access Control Policy and Standard (Project 8)
- Change Management Policy (implied by ITGC CM-01 through CM-03, Project 6)
- Asset Inventory (Project 4A)
- Enterprise Risk Register (Project 2), specifically risk R-02
- Statement of Applicability (Project 5B), specifically controls A.8.8 and A.5.7

8. CHANGE HISTORY

v1.0 (issued 2026-08-03): initial policy. Establishes scanning cadence, SLA-based remediation, prioritization using CVSS+KEV+EPSS+asset criticality, and formal exception process with maximum 90-day duration.